

A background image of several red onions, some whole and some cut in half, showing their layered internal structure. The image is slightly faded and has a soft, warm tone.

Security issues in TOR browser

Performed by Nikita Niakhai

Terms and description

“ **Tor (The Onion Router)** is a *free, open-source overlay network* designed to provide **anonymity** for TCP-based applications (web browsing, messaging, etc.) by routing traffic through multiple volunteer-operated relays, encrypting data in successive layers so no single relay knows both source and destination “ - spec.torproject.org

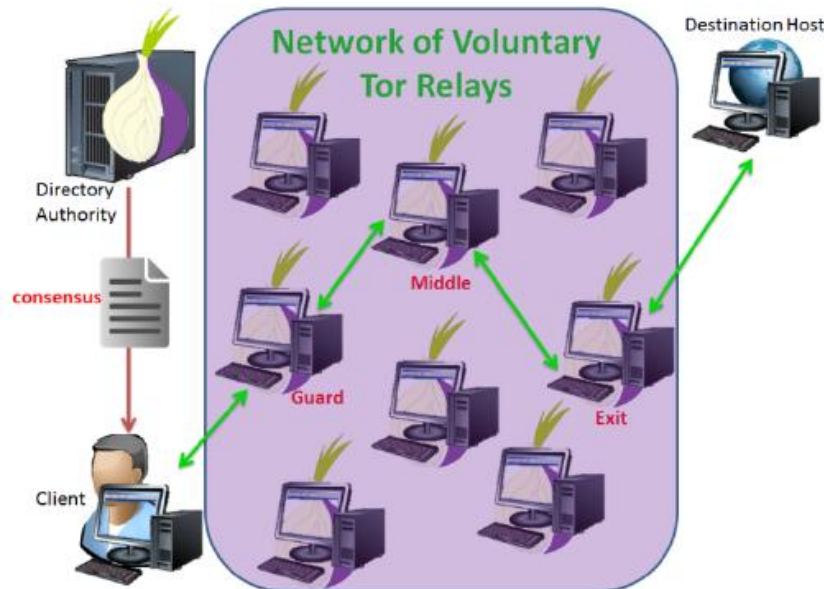
Distributed

Partially decentralized

TCP/IP - layer



” An umbrella only protects you from the rain if you have it with you and it is used as intended ”



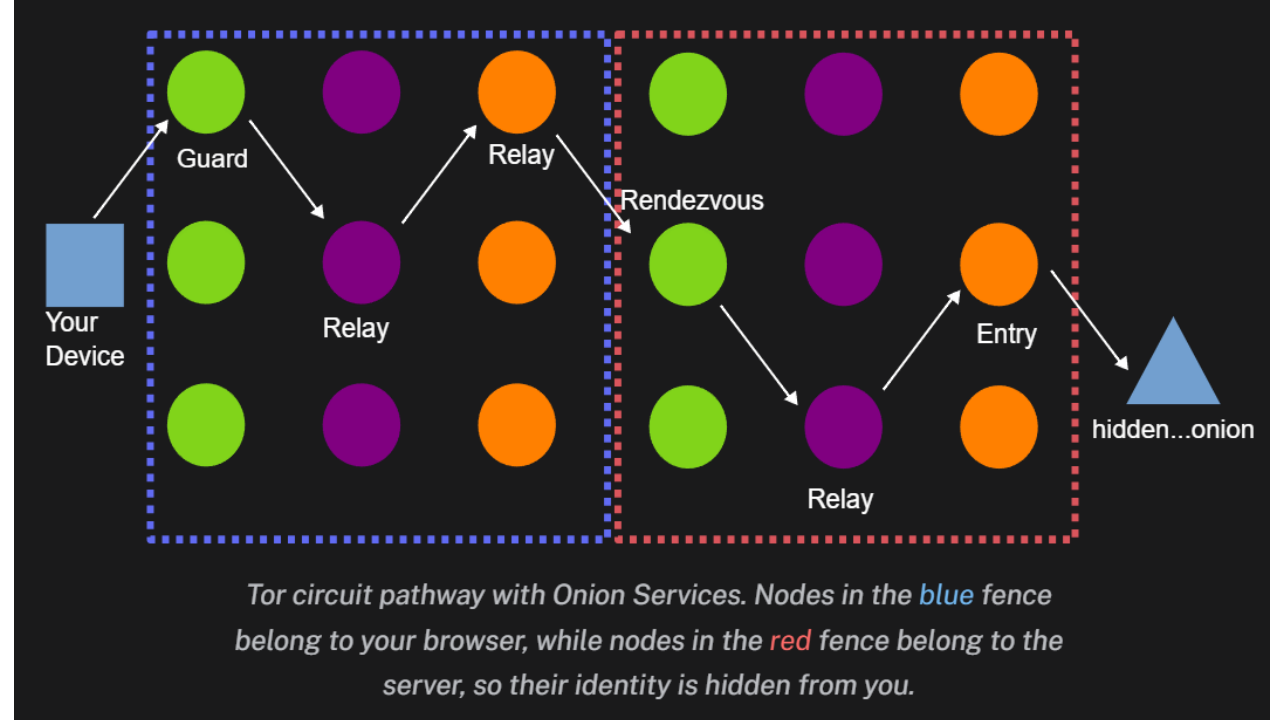
2	1	509 bytes				
CircID	CMD	DATA				
2	1	2	6	2	1	498
CircID	Relay	StreamID	Digest	Len	CMD	DATA

The architecture of the Tor cell circuit

Context

Main Use Cases:

- Journalists / activists / whistleblowers communicating sensitive info without revealing identity.
- hiding identity/location from websites, ISPs, trackers.
- accessing blocked content or sites via bridges / pluggable transports.
- hosting services anonymously so both clients and servers are shielded
 - Hidden services.



Actors:

- Client
- Relays / Nodes (Guard, Middle, Exit relay)
- Directory Authorities
- Bridge
- **Adversaries:** network observers, ISPs, malicious relays, state actors

Non-Functional requirements

- **Anonymity & Unlinkability:** infeasible for an adversary to link a user to their actions online.
- **Privacy under adversary models:** partial network control, compromised relays, local observer.
- **Low-latency communication:** cannot incur huge delays while preserving anonymity.
- **Scalability:** many users and many relay nodes.
- **Reliability / Availability**
- **Usability**
- **Resistance to relay compromise / malicious behavior:** guard relay selection, directory authorities trust, detection/removal of malicious nodes.
- **Transparency & open governance:** open source, clear policies, community review, audits.
- **Interoperability / compatibility.**

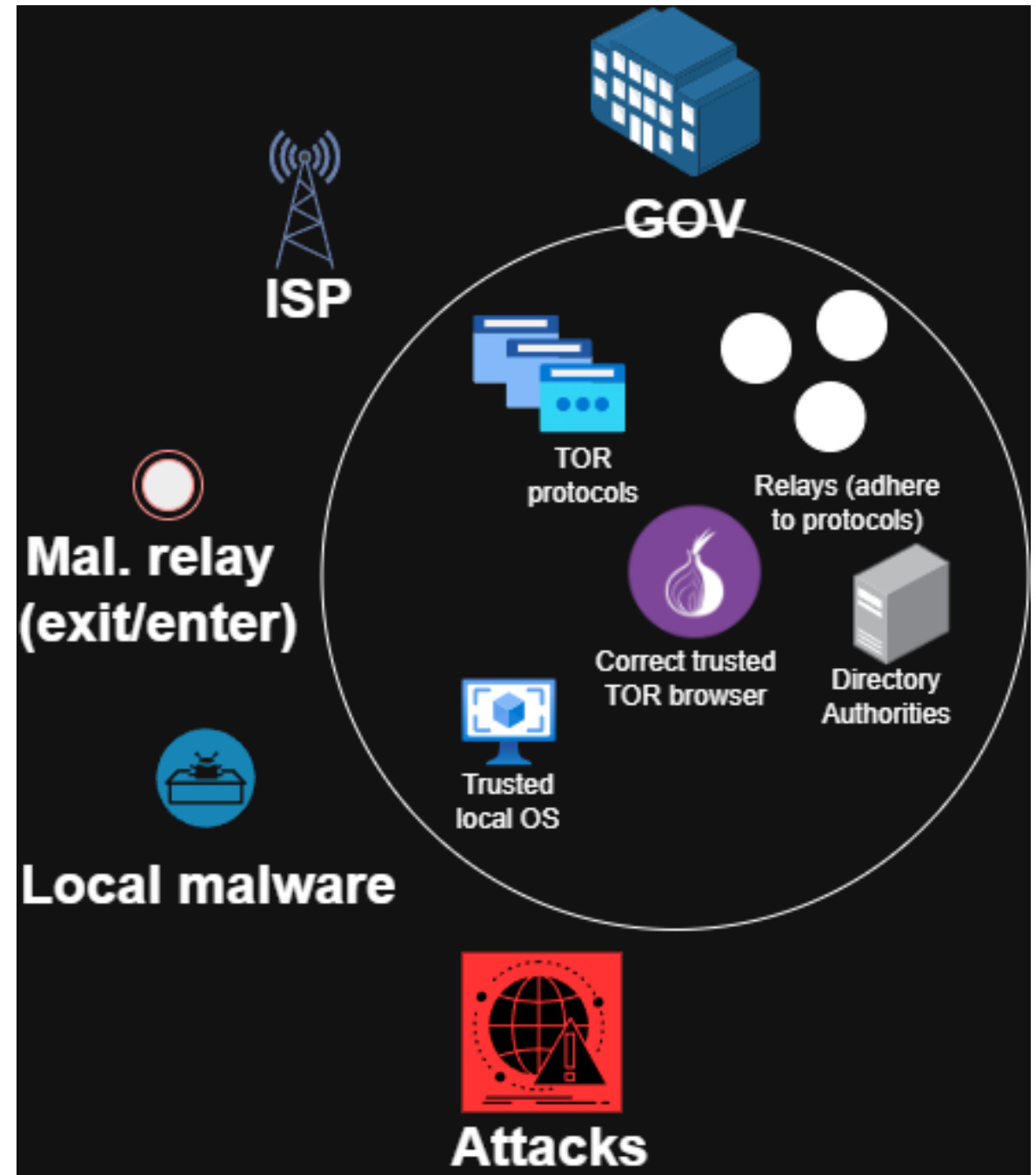
Safe Perimeter

Safe Perimeter / Security Boundaries:

- Trusted components: the user's Tor Browser client (assumed uncorrupted), the local OS (to some extent), correct implementation of Tor Browser / Tor protocol.
- Directory Authorities: semi-trusted; they can affect which relays are published, but should behave honestly (signing valid relay lists).
- Relays that adhere to protocol: guard, middle, exit relays that are not compromised/malicious.

Outside the Perimeter

- Network observers (ISPs, governments) who can observe traffic entering/leaving the Tor network.
- Malicious relays (especially exit, or a large fraction of nodes) trying to deanonymize or modify traffic.
- Local adversaries on user device (malware, browser plugins, misconfiguration).
- Censorship systems that block Tor or try to fingerprint its traffic.
- Timing attacks, correlation attacks across the network.



Possible attacks

- 1. Network & Protocol Layer:** Traffic correlation, AS/BGP routing hijacks, Sybil relay attacks.
- 2. Traffic & Side Channels:** Website fingerprinting (ML-based), in-page JS markers, DNS cache leakage.
- 3. Browser & Endpoint Exploits:** Fingerprinting, zero-days in Tor Browser (Firefox base), JS/microarchitectural timing leaks.
- 4. Infrastructure-Level Threats:** Malicious exit nodes (MITM, injection), DDoS to herd traffic.

Case Studies: Operation *Onymous* (2014) → endpoint + operational failure; Carnegie Mellon traffic confirmation (2014–2015) → relay-level deanonymization; German LE timing claims (2024).

Traffic correlation and BGP hijack attacks

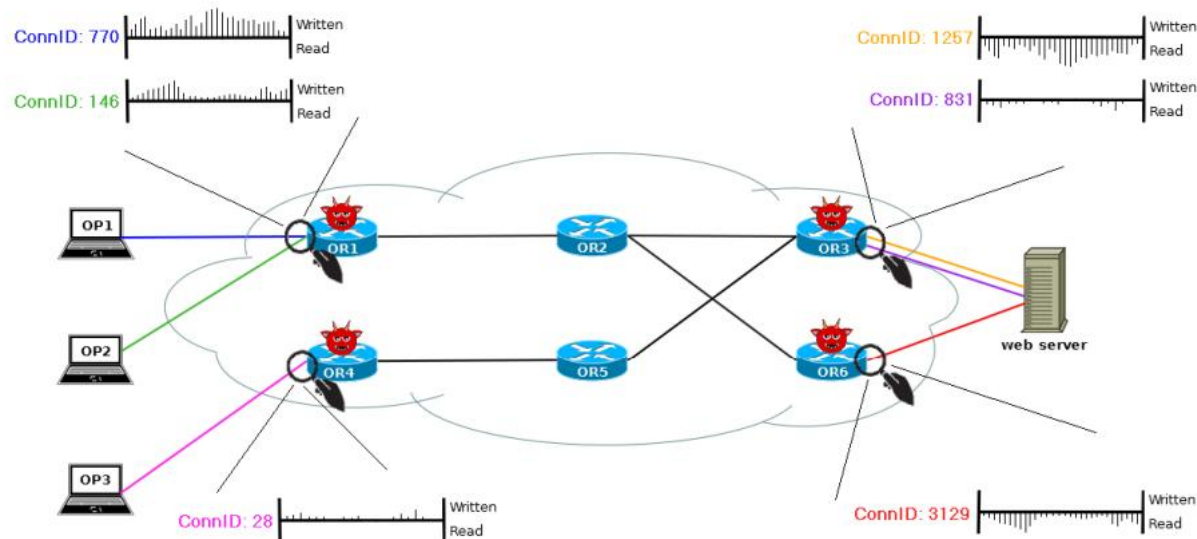
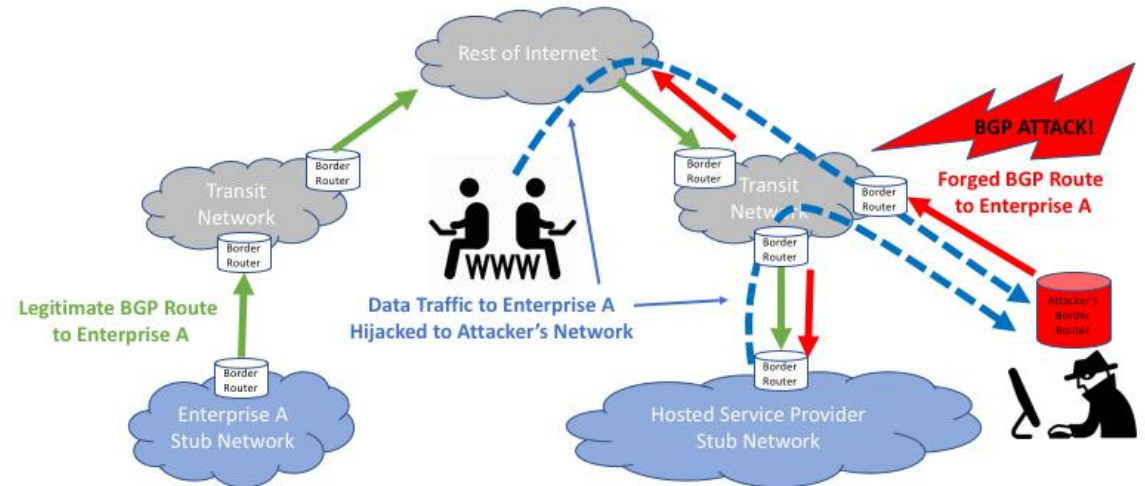
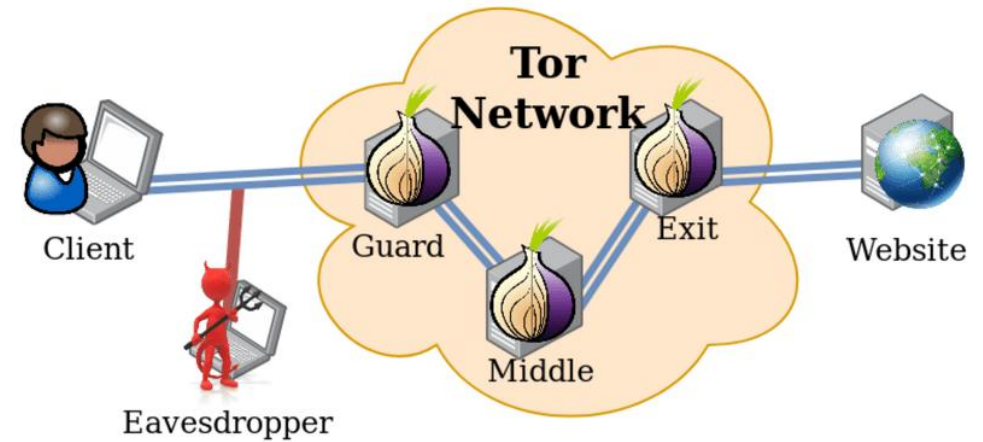
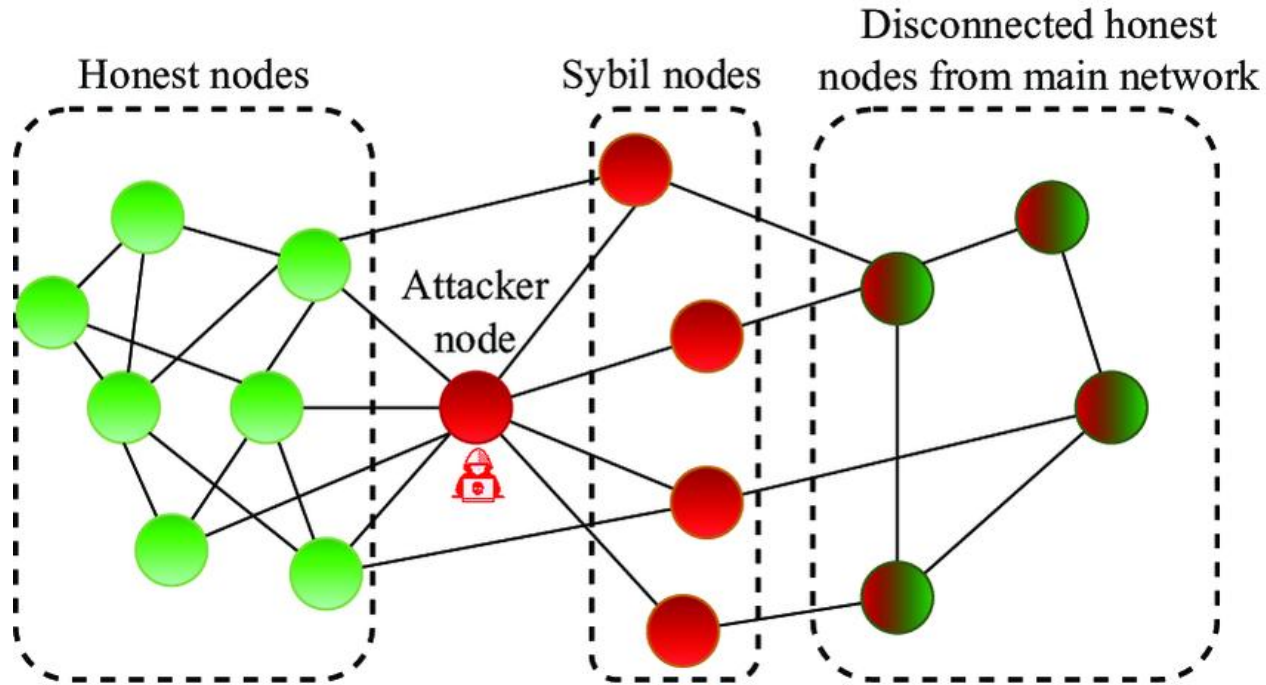


Figure 2.7: Example of TCP connections observable by a relay adversary who controls entry and exit relays in the Tor network.



<https://thesis.dial.uclouvain.be/server/api/core/bitstreams/85a56966-a488-4cb7-a88e-20024148bc7b/content>

Sybil attack and website fingerprinting threat model.



Forensic Analysis of Tor Browser: A Case Study for Privacy and Anonymity on the Web

- **Network Artifacts**
- **Public Keys of Tor Relays**
- **Email Content (Gmail/Yahoo)**
- **Google Drive Activity**
- **Social Media Profiles and Interactions**
- **Torrent and Academic Sites**
- **Research and Other Sites**
- **Mail2Tor (Onion Email Service)**

Case Studies: Forensic Analysis of Tor Browser: A Case Study for Privacy and Anonymity on the Web. Abid Khan Jadoon, Waseem Iqbal, Muhammad Faisal Amjad, Hammad Afzal, Yawar Abbas Bangash

References

- 1 - Forensic Analysis of Tor Browser: A Case Study for Privacy and Anonymity on the Web. Abid Khan Jadoon, Waseem Iqbal, Muhammad Faisal Amjad, Hammad Afzal, Yawar Abbas Bangash
- 2 - spec.torproject.org
- 3 - <https://www.princeton.edu/~pmittal/publications/bgptor-hotnets14.pdf>
- 4 - <https://blog.torproject.org/tor-security-advisory-relay-early-traffic-confirmation-attack/>
- 5 - https://en.wikipedia.org/wiki/Operation_Onymous
- 6 - <https://www.wired.com/2015/11/carnegie-mellon-denies-fbi-paid-for-tor-breaking-research/>